COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Application Attacks

Mestre CyberSec · **Aula 2.4 — Application Attacks** (11:48) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Aplicação = a superfície mais atacada: privilege escalation (horizontal = mesmo nível, outro dado; vertical = tier acima — user vira admin); directory traversal (../../etc/passwd); remote code execution. Defesa: input validation, patching, WAF, SCA (library vulnerable), secure co

💡 Highlights que a prova CompTIA cobra

- Privesc horizontal (mesmo nível, outro dado) vs vertical (tier acima)
- Directory traversal: sobe com ../ pra /etc/passwd
- Defesa: input validation SEMPRE; nunca confie no input

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'user gains higher-level access' = privilege escalation (vertical)
- 'path traversal reads arbitrary files' = directory traversal

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Application Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Escalação de Privilégio (PE)

Ataque em que um usuário obtém níveis de acesso não autorizados em um sistema. A escalação vertical sobe para um nível de privilégio maior (ex.: usuário para admin); a horizontal acessa outra conta no mesmo nível de privilégio.

⚠️ ***Armadilha CompTIA:*** *If the question says 'user gains higher-level access' or 'user becomes admin,' it is vertical privilege escalation. Horizontal = same level, different data/account.*

• Traversal de Diretório (DT)

Ataque de injeção que usa sequências como '../' (ponto-ponto-barra) em um caminho de arquivo para escapar do diretório pretendido e ler arquivos arbitrários no servidor, como /etc/passwd ou arquivos de configuração.

⚠️ ***Armadilha CompTIA:*** *Look for clues like '../', 'path traversal', or 'arbitrary file read.' The classic target file on Linux is /etc/passwd. Mitigation = input validation blocking '../' sequences.*

• Execução Remota de Código (RCE)

Vulnerabilidade crítica em que o atacante executa remotamente comandos ou código arbitrário no sistema alvo, geralmente por meio de falhas de injeção, bugs de deserialização ou serviços sem patch.

⚠️ ***Armadilha CompTIA:*** *RCE is the highest-severity outcome. Watch for terms 'arbitrary code execution,' 'shell access,' or 'command injection' leading to full system compromise.*

• Validação de Entrada (IV)

Prática de codificação segura que verifica, sanitiza e restringe toda a entrada fornecida pelo usuário contra uma allowlist de valores esperados antes do processamento, prevenindo ataques de injeção e traversal.

⚠️ ***Armadilha CompTIA:*** *The golden rule: 'Never trust user input.' Input validation is the first-line defense against SQLi, XSS, directory traversal, and command injection — expect it as the answer whenever these attacks appear.*

• Firewall de Aplicação Web (WAF)

Firewall especializado de Camada 7 que inspeciona tráfego HTTP/HTTPS para detectar e bloquear ataques web como SQL injection, XSS e traversal de diretório contra aplicações web.

⚠️ ***Armadilha CompTIA:*** *Distinguish WAF (Layer 7, protects web apps from HTTP-layer attacks) from NGFW (broader Layer 3-7 network protection). WAF = OWASP Top 10 shield.*

• Análise de Composição de Software (SCA)

Ferramenta de segurança que escaneia bibliotecas de terceiros, dependências e componentes open-source da aplicação contra bases de vulnerabilidades para identificar CVEs conhecidos e problemas de licenciamento.

⚠️ ***Armadilha CompTIA:*** *SCA = third-party/library scanning (Log4Shell-style vulnerabilities). Do not confuse with SAST (scans YOUR source code) or DAST (runtime black-box testing).*

• Injeção de SQL (SQLi)

Ataque de injeção em que instruções SQL maliciosas são inseridas em um campo de entrada para manipular o banco de dados backend, podendo expor, alterar ou apagar dados.

⚠️ ***Armadilha CompTIA:*** *Always pair SQLi mitigation with 'parameterized queries / prepared statements.' Input validation alone is NOT enough — keywords like 'UNION SELECT' or 'OR 1=1' are red flags.*

• Cross-Site Scripting (XSS)

Falha de injeção em que scripts maliciosos são injetados em uma página web confiável e executados no navegador da vítima. XSS stored persiste no servidor; reflected é entregue via link crafted.

⚠️ ***Armadilha CompTIA:*** *XSS targets the user's browser/client (not the server). Mitigation = output encoding and Content Security Policy (CSP). If the question mentions 'stealing cookies' or 'session hijacking via script,' think XSS.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Ataque On-path / Man-in-the-Middle (MitM)

🏠 **Analogia Intuitiva:** Pense em dois amigos conversando através de bilhetes de papel, mas o carteiro mal-intencionado abre cada envelope, lê os segredos de ambos, pode reescrever frases com mentiras e entrega a carta como se nada tivesse acontecido. Nenhum dos dois percebe que há um intermediário lendo e manipulando toda a conversa.

🔍 **Causa Raiz / Por que foi criado:** Comunicações de rede sem autenticação mútua ou sem criptografia forte de ponta a ponta confiam na infraestrutura de trânsito. O invasor se posiciona lógica ou fisicamente entre as partes para interceptar e modificar o tráfego.

🛡️ **Visão do Auditor de GRC:** Exigir TLS 1.3 obrigatório para todas as comunicações web e APIs; implementar mTLS (Mutual TLS) para comunicação entre serviços internos e proibir conexões remotas fora de VPNs corporativas criptografadas.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'adversary intercepts, relays, and potentially alters communications between two entities without their knowledge'. Resposta: On-path Attack (a terminologia oficial adotada pela CompTIA para Man-in-the-Middle).

📌 Envenenamento de ARP (ARP Poisoning / ARP Spoofing)

🏠 **Analogia Intuitiva:** Em uma sala aberta, o protocolo ARP é como alguém perguntar em voz alta: 'Quem aqui é o gerente da agência?'. O gerente de verdade está prestes a falar, mas um estelionatário grita mais rápido: 'Eu sou o gerente e este aqui é o meu crachá físico!'. Os presentes anotam o crachá falso em seus caderninhos e passam a entregar todo o dinheiro diretamente na mão do farsante.

🔍 **Causa Raiz / Por que foi criado:** O protocolo ARP foi concebido sem autenticação na Camada 2 (Enlace). Dispositivos aceitam respostas ARP não solicitadas (gratuitous ARP) e sobrescrevem cegamente suas tabelas ARP em memória de cache.

🛡️ **Visão do Auditor de GRC:** Incluir nas linhas de base de infraestrutura a obrigatoriedade de habilitar Dynamic ARP Inspection (DAI) e DHCP Snooping em todos os switches de acesso da rede local corporativa.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'attacker sends gratuitous ARP replies linking their MAC address with the IP address of the default gateway'. Resposta: ARP Poisoning / ARP Spoofing.

📌 SSL Stripping (Ataque de Downgrade de HTTPS)

🏠 **Analogia Intuitiva:** Você chega na porta de um banco querendo entrar na sala blindada e com isolamento acústico (HTTPS). O recepcionista desonesto diz: 'A sala blindada está em reforma, mas pode falar a sua senha e saldo aqui mesmo no balcão aberto (HTTP) que eu garanto a discrição'. Ele ouve tudo o que você fala e repassa para o banco dentro da sala segura, roubando suas credenciais em texto claro.

🔍 **Causa Raiz / Por que foi criado:** Navegadores frequentemente iniciam requisições em HTTP antes do redirecionamento 301/302 para HTTPS. Um atacante on-path intercepta o tráfego, mantém o canal seguro com o servidor legítimo, mas rebaixa a conexão com a vítima para HTTP não criptografado.

🛡️ **Visão do Auditor de GRC:** Fiscalizar a configuração de cabeçalhos HSTS (HTTP Strict Transport Security) com inclusão na lista pré-carregada (HSTS Preload) em todas as aplicações web públicas da organização.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'attacker intercepts communication and downgrades HTTPS connections to unencrypted HTTP to capture credentials in plaintext'. Resposta: SSL Stripping. Defesa primordial: HSTS.

📌 Defesa com DAI (Dynamic ARP Inspection) e DHCP Snooping

🏠 **Analogia Intuitiva:** O DAI é como o segurança na entrada da empresa que possui o livro oficial de crachás assinado pela administração (banco de dados do DHCP Snooping). Quando alguém grita na sala dizendo que é o diretor financeiro, o segurança confere o livro: 'Falso! Este crachá físico pertence ao estagiário!'. O segurança rasga o bilhete falso e expulsa o farsante na hora.

🔍 **Causa Raiz / Por que foi criado:** Switches comuns apenas encaminham quadros Ethernet sem inspecionar a autenticidade dos dados internos. O DAI inspeciona cada pacote ARP nas portas de acesso não confiáveis, descartando qualquer pacote com mapeamento IP-MAC divergente.

🛡️ **Visão do Auditor de GRC:** Auditar as configurações de rede local com testes de intrusão; validar que portas de computadores de usuários estejam configuradas como 'untrusted' e apenas portas de servidores DHCP legítimos estejam marcadas como 'trusted'.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'switch security feature that prevents ARP poisoning by validating packets against a trusted DHCP binding database'. Resposta: Dynamic ARP Inspection (DAI).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Invasor intercepta e manipula o tráfego entre cliente e servidor sem o conhecimento das partes	**Ataque On-path (Man-in-the-Middle)**
Mensagens ARP Reply falsas associando o endereço MAC do invasor ao IP do gateway da rede	**Envenenamento de ARP (ARP Poisoning / Spoofing)**
Rebaixamento forçado de uma sessão segura HTTPS para o protocolo inseguro HTTP em texto claro	**SSL Stripping (Downgrade Attack)**
Cabeçalho web que instrui o navegador a comunicar-se exclusivamente via HTTPS criptografado	**HSTS (HTTP Strict Transport Security)**
Recurso de hardware em switch que bloqueia pacotes ARP forjados inspecionando portas não confiáveis	**DAI (Dynamic ARP Inspection)**
Técnica de camada 2 que mapeia e armazena os pares legítimos de IP e MAC concedidos por DHCP	**DHCP Snooping**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança revisa logs de servidor web e vê solicitações repetidas de URLs como /download?file=../../../../etc/passwd e /download?file=..%2f..%2fconfig.php. A aplicação está retornando conteúdo de arquivos fora do diretório pretendido. Qual ataque de aplicação está ocorrendo?

A) Injeção de SQL

B) Cross-site scripting

C) Directory traversal

D) Escalação de privilégios

QUESTÃO 2 · CENÁRIO DE EXAME

Uma aplicação web reflete o valor de um parâmetro de busca diretamente na resposta HTML sem codificação. Um atacante envia um termo de busca contendo uma tag de script maliciosa, e o script é executado no navegador de outros usuários quando eles visualizam os resultados da busca. Qual vulnerabilidade está sendo explorada?

A) Cross-site scripting refletido

B) Injeção de SQL

C) Directory traversal

D) Execução remota de código

QUESTÃO 3 · CENÁRIO DE EXAME

Um formulário de login monta uma consulta ao banco de dados concatenando os campos de nome de usuário e senha diretamente na instrução SQL. Um atacante insere um nome de usuário especialmente criado que altera a lógica da consulta e contorna a autenticação. Qual ataque é este?

A) Cross-site request forgery

B) Injeção de SQL

C) Directory traversal

D) Cross-site scripting

QUESTÃO 4 · CENÁRIO DE EXAME

Um usuário autenticado em uma aplicação bancária online altera o parâmetro de ID de conta em uma requisição do próprio número de conta para o número de conta de outro cliente. A aplicação retorna os detalhes da conta do outro cliente, embora ambos tenham o mesmo papel. Que tipo de escalação de privilégios é esta?

A) Escalação de privilégios vertical

B) Escalação de privilégios horizontal

C) Directory traversal

D) Execução remota de código

QUESTÃO 5 · CENÁRIO DE EXAME

Um atacante com uma conta de usuário padrão manipula um parâmetro oculto em uma requisição de atualização de perfil. A aplicação então concede à conta acesso a funções administrativas normalmente restritas à equipe de TI. Que tipo de escalação de privilégios ocorreu?

A) Escalação de privilégios horizontal

B) Escalação de privilégios vertical

C) Injeção de SQL

D) Cross-site scripting

QUESTÃO 6 · CENÁRIO DE EXAME

Uma aplicação web permite que usuários façam upload de arquivos de imagem. Após o upload, o servidor processa os metadados usando uma biblioteca que invoca um comando externo. Um atacante embute comandos de shell nos metadados, e o servidor os executa com as permissões da conta do serviço web. Qual vulnerabilidade foi explorada?

A) Cross-site scripting

B) Directory traversal

C) Execução remota de código

D) Análise de composição de software

QUESTÃO 7 · CENÁRIO DE EXAME

Uma equipe de desenvolvimento deseja identificar vulnerabilidades conhecidas em bibliotecas e frameworks de código aberto usados por suas aplicações. A equipe precisa de uma ferramenta que faça inventário de dependências e as relacione a CVEs conhecidas. Que tipo de análise deve ser usada?

A) Teste dinâmico de segurança de aplicações

B) Análise de composição de software

C) Firewall de aplicação web

D) Teste estático de segurança de aplicações

QUESTÃO 8 · CENÁRIO DE EXAME

Uma organização deseja proteger uma aplicação web pública contra ataques comuns de injeção antes que as requisições cheguem aos servidores de aplicação. A equipe de segurança precisa de um controle que inspecione o tráfego HTTP e possa bloquear padrões maliciosos. Qual controle atende melhor a esse requisito?

A) Análise de composição de software

B) Firewall de aplicação web

C) Validação de entrada

D) Gestão de patches

QUESTÃO 9 · CENÁRIO DE EXAME

Durante uma revisão de código, um engenheiro de segurança descobre que um formulário web depende apenas de verificações JavaScript no navegador para validar os campos de idade e código postal. Atacantes podem contornar essas verificações e enviar valores maliciosos diretamente ao servidor. Qual defesa deve ser adicionada?

A) Firewall de aplicação web

B) Validação de entrada no lado do servidor

C) Análise de composição de software

D) Prevenção de directory traversal

QUESTÃO 10 · CENÁRIO DE EXAME

Um recurso de download de arquivos constrói um caminho de arquivo a partir de um parâmetro fornecido pelo usuário. Os desenvolvedores querem impedir que atacantes acessem arquivos fora do diretório de download pretendido. Qual controle deve ser implementado?

A) Codificar toda a saída HTML antes de renderizar páginas

B) Canonicalizar o caminho e validá-lo contra uma allowlist ou diretório base

C) Usar consultas de banco de dados parametrizadas para todas as buscas de metadados de arquivos

D) Executar teste dinâmico de segurança de aplicações no ambiente de homologação

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Directory traversal

Directory traversal usa sequências ../ ou variantes codificadas para sair do diretório pretendido e acessar arquivos fora da raiz web. SQLi ataca consultas de banco de dados, XSS ataca execução no navegador, e escalação de privilégios obtém direitos superiores; a manipulação de caminho de arquivo é o indicador principal.

Questão 2: Alternativa A — Cross-site scripting refletido

XSS refletido ocorre quando a entrada do usuário é retornada imediatamente na resposta sem codificação de saída, permitindo que scripts sejam executados no navegador da vítima. SQLi afeta consultas ao banco de dados, directory traversal acessa arquivos, e RCE executa código no servidor.

Questão 3: Alternativa B — Injeção de SQL

Injeção de SQL ocorre quando entrada não confiável altera a estrutura de uma consulta SQL. Neste caso, o nome de usuário criado altera a condição da consulta para contornar a autenticação. CSRF abusa de sessões autenticadas, directory traversal manipula caminhos de arquivo, e XSS executa scripts em navegadores.

Questão 4: Alternativa B — Escalação de privilégios horizontal

Escalação de privilégios horizontal ocorre quando um usuário acessa recursos pertencentes a outro usuário no mesmo nível de privilégio. A escalação vertical envolveria obter privilégios superiores, como se tornar administrador.

Questão 5: Alternativa B — Escalação de privilégios vertical

Escalação de privilégios vertical ocorre quando um usuário obtém um nível de acesso superior, como passar de usuário padrão para administrador. A escalação horizontal envolveria acessar recursos de outro usuário no mesmo nível.

Questão 6: Alternativa C — Execução remota de código

Execução remota de código permite que um atacante execute comandos ou código arbitrários no servidor. Os comandos de shell embutidos executados pelo servidor indicam RCE. XSS é executado no navegador, directory traversal lê arquivos, e SCA é um processo de análise de dependências, não um ataque.

Questão 7: Alternativa B — Análise de composição de software

Análise de composição de software (SCA) examina componentes e dependências de terceiros para identificar vulnerabilidades conhecidas e questões de licença. DAST testa aplicações em execução, SAST analisa código-fonte, e um WAF bloqueia tráfego em tempo de execução.

Questão 8: Alternativa B — Firewall de aplicação web

Um firewall de aplicação web (WAF) inspeciona tráfego HTTP/HTTPS e pode bloquear ataques comuns como injeção de SQL e XSS antes que cheguem à aplicação. SCA analisa dependências, validação de entrada é implementada na aplicação, e gestão de patches corrige falhas conhecidas de software.

Questão 9: Alternativa B — Validação de entrada no lado do servidor

Validação de entrada no lado do servidor garante que os dados sejam validados no servidor independentemente das verificações do lado do cliente, que podem ser contornadas. Um WAF pode ajudar, mas não substitui o tratamento seguro de entrada; SCA e prevenção de directory traversal tratam de outros problemas.

Questão 10: Alternativa B — Canonicalizar o caminho e validá-lo contra uma allowlist ou diretório base

Canonicalizar o caminho e validá-lo contra uma allowlist ou diretório base impede directory traversal ao resolver sequências de caminho relativas e codificadas antes do acesso ao arquivo. Codificação de saída trata XSS, consultas parametrizadas tratam injeção de SQL, e DAST é um método de teste, não um controle preventivo.